

Diversity Survey Governance and Incident Response Playbook

Document type	Operational governance manual
Coverage	Cultural Infusion Atlas - synthetic research snapshot
Topics	governance retention access control incident response consent free text
Source inspiration	https://atlas.culturalinfusion.com/secure-diversity-inclusion-survey-trust/

This document is a synthetic test artifact derived from themes and publicly visible metadata in the supplied Atlas article. It contains paraphrase, explanatory expansion and invented scenarios. It is not legal advice, a real client record, or a substitute for the original source and linked academic paper.

Governance roles

The fictional survey owner defines purpose and approved questions. The privacy lead reviews legal basis, notice, minimisation, rights and retention. The security lead owns technical safeguards and incident coordination. The people analytics lead validates measures and disclosure controls. Local representatives confirm jurisdiction and workforce context.

No single role can approve every stage. Launch requires recorded sign-off from the survey owner, privacy lead and analytics lead. High-risk free text or cross-border changes also require security review. Bob may explain these roles but must not claim to perform an approval.

Purpose and question review

Every question maps to an analytical purpose and proposed decision. Questions retained merely because they may be useful later are removed. Category design is reviewed for cultural relevance, respondent self-description, comparability and the risk that a category is too granular for the workforce size.

Optional questions are labelled clearly. Prefer-not-to-say remains available where appropriate and is analysed as a response rather than silently discarded. Survey owners document which decisions will not be made from the data, including individual performance and hiring decisions.

Access matrix

Respondents can view the notice and their submission confirmation but not other responses. Client administrators manage campaigns but cannot open row-level identity data. Approved analysts access de-identified datasets in a controlled environment. Executives receive thresholded aggregates. Support access is time-bound and ticket-linked.

The synthetic matrix denies line managers any special visibility into their team's raw answers. A minimum group threshold applies even if a manager claims to know every team member. Emergency access requires two-person approval and generates an immutable alert.

Retention and deletion

Invitation contact data is retained for ninety days after campaign closure. Pseudonym mappings are retained for one hundred and twenty days to support verified correction and deletion requests. De-identified response data is retained for twenty-four months. Aggregate benchmark statistics may be retained longer only if the approved method prevents re-identification.

These periods are fictional defaults and can be shortened by contract or jurisdiction. Deletion covers primary stores, derived datasets, caches and scheduled backup expiry. Completion is evidenced through a deletion job record rather than a manual assurance alone.

Incident classification

SEV-1 covers confirmed unauthorised access to raw sensitive responses or credible risk of widespread harm. SEV-2 covers a limited disclosure, compromised privileged account or export sent to the wrong authorised organisation contact. SEV-3 covers blocked attempts, policy deviations without exposure, or delayed deletion with low immediate harm.

Classification can rise as facts change. The incident commander preserves evidence, contains access, consults privacy and legal specialists, evaluates notification duties, communicates with affected clients and records corrective actions. Public statements should distinguish known facts from investigation hypotheses.

Small-cohort disclosure scenario

A client creates a filter combining regional office, seniority and language and receives a chart representing four people despite a configured threshold of ten. The incident team disables the filter path, preserves query logs, checks whether an export occurred and tests related combinations. The cause is a caching rule that applied the threshold before, rather than after, a secondary filter.

The event is classified SEV-2 because an authorised client user could infer a small cohort. Remediation clears affected caches, patches query planning, adds privacy regression cases and notifies the client under the agreed process. No claim is made that a named individual was identified without supporting evidence.

Free-text scenario

A respondent writes a detailed account containing colleague names and a medical condition. Automated detection quarantines the comment from ordinary analytics. A restricted reviewer removes unnecessary identifiers and records the reason. The original follows a short protected retention path required for incident assessment.

Free text should not be treated like another category field. It needs clear respondent guidance, collection justification, access restrictions, redaction, moderation and a plan for urgent safeguarding content. Removing free text entirely may reduce insight, but collecting it without controls transfers risk to respondents.

Assurance schedule

Monthly checks cover privileged access and deletion queues. Quarterly checks cover restore tests, threshold bypass attempts and vendor access. Annual review covers purpose, categories, jurisdiction changes, threat model and incident exercises. A material architecture or use change triggers an out-of-cycle review.

Evidence is stored as dates, owners, test results, exceptions and remediation status. A policy document without operating evidence is not considered assurance.